The 4X Cyber Attack Framework

Modeling Autonomous Adversary Loops

Aubrey Finn

Threat Modeling & Detection Engineering Research

Portfolio Technical Brief | Revision 1.1 | October 13, 2026

Executive Summary

The 4X Framework organizes adversary behavior into **eXplore, eXpand, eXploit, and eXfiltrate**. Each name begins with eX. The model emphasizes repeated observation, action, and reassessment within a compromised environment. Its intended contribution is a compact way to connect changing attacker objectives to trust boundaries and defensive evidence.

4X complements MITRE ATT&CK, which supplies an established taxonomy of adversary tactics and techniques [1]. ATT&CK does not require a fixed execution order or human-paced activity. 4X adds a proposed decision-loop view for scenario design and event correlation; it does not establish that existing frameworks cannot represent automated threats.

Research status: This brief proposes a conceptual model and an illustrative validation design. It reports no completed experiments, detection-performance measurements, or new vulnerabilities. The model applies to scripted and human-directed activity as well as potentially autonomous agents. Autonomy must be demonstrated through observed decision behavior, not inferred from speed alone.

1. Scope and Assumptions

The primary scope is post-compromise behavior on Windows endpoints, with application credential stores as an example. Initial access is an explicit precondition, not a fifth phase. Cloud and cross-host application would require separate validation.

The assumed adversary can execute a process in a user's session. Configuration modification and process-memory access depend on permissions, integrity levels, process protections, and application state. A shared session does not guarantee unrestricted access [2]. Activity using existing permissions can occur without administrative elevation; this alone is not a UAC bypass.

Record the host, principal, process identity, application version, accessible resources, sensitive-data state, and sensors. Identify the boundary: process memory, configuration integrity, application authorization, or approved network egress.

2. Operational Model and Transition Rules

The four phases describe objectives rather than mandatory steps. They can repeat, overlap, or be skipped. Discovery can resume after any action. Exfiltration may fail or occur in small batches. Cleanup is cross-cutting behavior, not an additional eX phase.

Phase	Objective	Decision evidence
eXplore	Identify resources, protections, and workflow state.	Target found; prerequisite known; useful state observed.
eXpand	Increase reachable resources or persistence within available privileges.	Access obtained; staging available; action denied.
eXploit	Abuse a feature or vulnerability to achieve unauthorized access or collection.	Data accessible; action succeeded; control blocked it.
eXfiltrate	Transfer information outside its approved boundary.	Transfer attempted, blocked, or confirmed.

State record: Maintain a timestamped tuple of objective, host, principal, process, target resource, observed condition, attempted action, outcome, and evidence confidence. Keep unknown outcomes explicit. Assign labels from observed behavior; a tool name alone is insufficient.

Proposed transition	Condition	Defensive interpretation
eXplore to eXpand	Target identified; more access or staging needed.	Link discovery to a subsequent access change.
eXplore to eXploit	Required access already exists.	Do not require expansion to detect abuse.
eXpand to eXploit	Access prerequisite satisfied.	Link the change to the affected resource.
eXploit to eXfiltrate	Information collected; outbound path available.	Collection alone does not prove transfer.
Any phase to eXplore	Failure, changed conditions, or a new target.	Preserve context across retries.

ATT&CK association: Candidate mappings include T1057 and T1082 for eXplore; T1055 or T1053 for eXpand when behavior supports them; T1555 or T1546 for eXploit; and T1041 or T1567 for eXfiltrate. These are illustrative associations, not automatic classifications. Select applicable sub-techniques from evidence and record the ATT&CK version used [1].

3. Credential Stores and Trust Boundaries

Database encryption protects stored content under its defined assumptions. Endpoint compromise creates additional risks around authorized decryption, input, configuration, and transfer. This differs from defeating the cipher. Identify which attacker capabilities expose sensitive data in a particular application state.

Historical memory-disclosure example

CVE-2023-32784 describes recovery of the KeePass master password, except its first character, from memory dumps in KeePass 2.x before 2.54. The record includes process, swap, hibernation, and full-system dumps; version 2.54 introduced mitigation [3]. This historical example does not establish that current vaults expose all stored passwords or that an agent captured an unlock event in real time.

Configuration abuse and vendor position

CVE-2023-24055 describes an export-trigger scenario requiring write access to the KeePass XML configuration in affected installations [4]. The vendor disputes treating configuration write access as a KeePass vulnerability, emphasizing that such access commonly implies broader control of the user's environment [5]. The relevant boundary is configuration integrity under an already-capable local adversary.

Specify application version, installation type, effective configuration, policy restrictions, and attacker permissions. Do not assume success across all releases or configurations. Enforced configuration can constrain supported application settings when the enforced file and containing directory are protected [6]. This does not eliminate all risks from malware running with the user's rights.

Protection scope

Separate Windows authentication-secret protection from third-party application protection. Credential Guard isolates selected Windows credentials; Microsoft excludes software managing credentials outside Windows feature protection [7]. It should not be presented as protecting a KeePass database or ordinary vault-process memory.

Protected Process Light applies to supported protected-process scenarios, including LSA protection, rather than serving as a generic switch for arbitrary applications. Evaluate application-specific protections, least privilege, application control, configuration integrity, and endpoint monitoring together. No single control here guarantees confidentiality on a compromised endpoint.

4. Defensive Evidence and Control Scope

Phase	Candidate evidence	Controls and limits
eXplore	EDR discovery telemetry; filtered Sysmon Event 10.	Baseline expected process access. Event 10 does not cover every enumeration action or hook.
eXpand	Configuration-integrity changes; file creation; persistence evidence.	Protect policy files and directories; use application control. Event 11 is not a complete file-change audit.
eXploit	Application audit records; unexpected child processes; relevant IPC.	Enforce supported policy. In-process abuse may spawn no child; benign automation can look similar.
eXfiltrate	Process-linked connections, DNS, proxy logs, receiver records.	Restrict egress. TLS metadata does not reveal encrypted content; a connection alone does not prove exfiltration.

Sysmon supplies events rather than verdicts. Examples are Event 1 for process creation, Event 3 for network connections, Event 10 for process access, and Event 22 for DNS queries. Enable and filter required telemetry; network monitoring is disabled by default [8]. Use file-integrity monitoring or suitable EDR coverage for configuration changes.

Correlate by host, principal, process GUID, resource, and time. Use ancestry when actions move between processes. Missing telemetry means unknown, not proof of inactivity. Diagnostics, backups, synchronization, and administrative changes are important benign comparisons.

5. Illustrative Validation Design

Status: proposed, not executed. Use an isolated lab, a mock vault or test application, synthetic credentials, and a controlled local receiver. Record versions, policies, permissions, and sensors.

1. Establish a benign baseline: ordinary unlock, backup, synchronization, and authorized configuration changes.

2. Use a benign harness to record discovery, an approved test configuration change, synthetic export, and transfer to the lab receiver. Label these simulated phases, not proven exploitation.

3. Compare a complete sequence, direct eXplore-to-eXploit activity, blocked egress, repeated discovery, and missing-sensor runs.

4. Evaluate correlation of an unusual configuration change, synthetic collection, and process-linked transfer. Start with a five-minute window as a lab parameter and assess its effect.

5. Preserve raw events and receiver records. Report expected versus observed evidence, alert latency, misses, benign alerts, and outcomes with and without the relevant control.

A mock-application run validates instrumentation and correlation only. It does not validate a KeePass CVE, establish autonomy, or prove effectiveness against real adversaries. Future measured results must identify scenario, sample size, ground truth, and limitations.

6. Industry Application and Limitations

4X can support threat-model reviews, tabletop exercises, detection hypotheses, and purple-team planning by connecting objectives to boundaries, observations, and controls. Compare it with an ATT&CK-only baseline: does the added state record expose a missed transition, improve correlation, or clarify a control gap?

The four labels compress distinct behaviors and are not mutually exclusive. Most examples concern one Windows endpoint. The model does not establish novel tradecraft, generalize to every credential store, or show that automation requires AI. Detection depends on coverage and tuning. Memory cleanup does not guarantee removal of independent endpoint or network evidence.

Aubrey Finn | Threat Modeling & Detection Engineering

Portfolio focus: security architecture, application trust boundaries, adversary modeling, and evidence-driven defensive engineering.

7. References

Primary documentation and vulnerability records reviewed for this revision. Consult current product documentation before implementation.

1. MITRE. *ATT&CK: Design and Philosophy* (March 2020). https://attack.mitre.org/docs/ATTACK_Design_and_Philosophy_March_2020.pdf

2. Microsoft. *Process Security and Access Rights*. https://learn.microsoft.com/en-us/windows/win32/procthread/process-security-and-access-rights

3. CVE-2023-32784 record, GitHub Advisory Database. https://github.com/advisories/GHSA-f4c7-5p8v-p7jh

4. NIST National Vulnerability Database. *CVE-2023-24055*. https://nvd.nist.gov/vuln/detail/CVE-2023-24055

5. KeePass. *Security Issues: Write Access to Configuration File*. https://keepass.info/help/kb/sec_issues.html

6. KeePass. *Enforced Configuration*. https://keepass.info/help/kb/config_enf.html

7. Microsoft. *How Credential Guard Works*, including protection limits. https://learn.microsoft.com/en-us/windows/security/identity-protection/credential-guard/how-it-works

8. Microsoft Sysinternals. *Sysmon*. https://learn.microsoft.com/en-us/sysinternals/downloads/sysmon

Revision Notes

Revision 1.1 preserves eX naming; positions 4X as complementary to ATT&CK; defines proposed state records and transitions; corrects privilege and credential-protection claims; qualifies historical KeePass examples; and adds validation design and references. No empirical results are claimed.